

# inductive-automation-ignition brief

---

## Inductive Automation Ignition Firmware Attack Surface & Detection Brief

---

**Scope:** Research-only brief — firmware extraction is pending and no Ignition Gateway binaries are yet present in `firmware-staging/Inductive-Automation/`. Covers 6 product lines (Gateway, Edge, Maker Edition, Designer Launcher, Vision Client, Perspective Workstation) across 5 architecture classes. Findings combine NVD/CVE records, Inductive Automation security bulletins, CISA ICS advisories, and named research from Claroty Team82 and Dragos. Hash count: 0 (analyst queue priming only). Distinct from native-code SCADA threat models — Ignition's attack surface is dominated by the embedded JVM, HTTP/HTTPS gateway, and SQL historian backend, not C-runtime memory corruption.

**Purdue layer mapping:** Group A (Gateway) and Group C (Maker) land at L3 Site Operations — see [docs/purdue-l3-site-operations-brief.md](#). Group B (Edge) straddles L2/L3.5 — see [docs/purdue-l2-area-supervisory-brief.md](#) and [docs/purdue-l35-it-ot-boundary-brief.md](#). Group D Designer sits at L3 EWS; Vision Client and Perspective Workstation runtime on operator panels sit at L2 — see [docs/purdue-l2-area-supervisory-brief.md](#). Group E SQL historian backends sit at L3 data tier. RTU/PLC south of the Gateway lives at L1 — see [docs/purdue-l1-basic-controllers-brief.md](#). Safety PLCs out of band — see [docs/purdue-safety-systems-brief.md](#).

### Architecture grouping (drives the threat model, not the SKU)

---

| Class             | Purdue layer       | Products                     | Stack                                                                            | Catalog depth                      |
|-------------------|--------------------|------------------------------|----------------------------------------------------------------------------------|------------------------------------|
| A — SCADA Gateway | L3 Site Operations | Ignition Gateway (Win/Linux) | Java 17 JVM + Jetty + embedded WrapperManager + internal H2/Derby + OPC UA stack | Research-only (extraction pending) |
| B — Edge Gateway  | L2 / L3.5 boundary | Ignition Edge                | Same Gateway binary base, license-restricted                                     | Research-only                      |
| C — Maker Edition | L3 (lab/home)      | Ignition Maker               | Same Gateway binary, non-commercial license                                      | Research-only                      |

| Class             | Purdue layer                                                 | Products                                                  | Stack                                                                     | Catalog depth               |
|-------------------|--------------------------------------------------------------|-----------------------------------------------------------|---------------------------------------------------------------------------|-----------------------------|
| D — Clients       | L3 EWS (Designer) / L2 HMI (Vision, Perspective Workstation) | Designer Launcher, Vision Client, Perspective Workstation | Java Web Start successor (JxBrowser/Chromium for Perspective Workstation) | Research-only               |
| E — SQL Historian | L3 data tier                                                 | MS SQL Server / PostgreSQL / MySQL backend                | Vendor DB engine, configured by integrator                                | Out of scope (DB hardening) |

## Group A — Ignition Gateway — Purdue L3 (Site Operations)

- **Direct attack surface** — TCP 8088 (HTTP), 8043 (HTTPS), 8060 (Gateway Network for redundancy/EAM), 62541 (embedded OPC UA server), 4840 (UA client). Default admin credential `admin/password` on first install — Inductive Automation does not force rotation in the installer wizard. Java serialization endpoints exposed via Gateway Network. Module installation via signed `.mod1` (PKCS7-signed JAR variant) — module signing is the primary supply-chain boundary.
- **Confirmed CVEs / advisories**

| CVE                                                                          | CVSS | Product | Vector                                                      | Status                                                                                      |
|------------------------------------------------------------------------------|------|---------|-------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| Inductive Automation security bulletins — Gateway Network auth bypass family | —    | Gateway | Auth bypass via Gateway Network (Claroty Team82 disclosure) | See <a href="https://inductiveautomation.com/security">inductiveautomation.com/security</a> |
| Inductive Automation security bulletins — web endpoint traversal family      | —    | Gateway | Directory traversal via web endpoint                        | See <a href="https://inductiveautomation.com/security">inductiveautomation.com/security</a> |
| <a href="#">ICSA-23-220-01</a>                                               | —    | Gateway | Multiple Claroty Team82 findings (deserialization + auth)   | Family reference                                                                            |
| <a href="#">ICSA-22-242-09</a>                                               | —    | Gateway | Project-file parsing / XXE family                           | Family reference                                                                            |

- **Top attack vector (MITRE ATT&CK ICS):** [T0812 Default Credentials](#) abusing the unrotated `admin/password` default, chained with [T0866 Exploitation of Remote Services](#) via Gateway-side Jython tag-change scripts to achieve persistence inside the SCADA itself.

## Group B — Ignition Edge — Purdue L2 / L3.5

---

- **Direct attack surface** — same binary base as Gateway, license-gated to a smaller tag count. Deployed on small Linux gateways (e.g., MQTT-Engine, Sparkplug B brokers). Often sits inside the DMZ between L2 cell and L3 site SCADA, making it an L3.5 conduit. MQTT TCP 1883 / TLS 8883 when paired with Cirrus Link MQTT Transmission/Engine modules.
- **Confirmed CVEs / advisories** — inherits Group A CVEs (same gateway binary). Sparkplug B implementation flaws tracked by [Claroty Team82](#) — broker takeover lets an attacker spoof PLC tag updates upstream. See [ICSA-22-242-09](#).
- **Top attack vector (MITRE ATT&CK ICS):** [T0830 Adversary-in-the-Middle](#) on the MQTT broker to inject false tag values into the upstream historian, producing [T0832 Manipulation of View](#) for the L3 operator.

## Group C — Maker Edition — Purdue L3 (lab/home)

---

- **Direct attack surface** — identical to Group A. Concern is supply chain: free download + permissive licensing means red teams and threat actors trivially obtain a full Gateway for offensive R&D. Treat as the same threat surface as Group A; do NOT treat as a sandboxed lite build.
- **Confirmed CVEs / advisories** — same CVE corpus as Group A; Inductive Automation security bulletins at [inductiveautomation.com/security](https://inductiveautomation.com/security) cover the whole binary line, not per-edition.
- **Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) — malicious `.mod1` module crafted/tested against Maker, deployed to a production Gateway with relaxed module-signing policy.

## Group D — Designer / Vision / Perspective Workstation clients — Purdue L3 EWS (Designer) / L2 HMI (Vision, Perspective Workstation)

---

- **Direct attack surface** — Designer Launcher and Vision Client are Java client apps that pull project resources from the Gateway over HTTPS; project files are XML/JSON with Jython expressions. Perspective Workstation embeds JxBrowser (Chromium) for web rendering. Client-side script execution (Jython in Vision, JS in Perspective) is the implicit RCE primitive once a malicious project is loaded.
- **Confirmed CVEs / advisories**

| CVE                                       | CVSS | Product  | Vector                                  | Status                                                                                      |
|-------------------------------------------|------|----------|-----------------------------------------|---------------------------------------------------------------------------------------------|
| Inductive Automation security bulletins — | —    | Designer | Path traversal in module/project import | See <a href="https://inductiveautomation.com/security">inductiveautomation.com/security</a> |

| CVE                                      | CVSS | Product | Vector                                    | Status           |
|------------------------------------------|------|---------|-------------------------------------------|------------------|
| Designer project-import traversal family |      |         |                                           |                  |
| <a href="#">ICSA-23-220-01</a>           | —    | Vision  | Claroty Team82 project-file parsing chain | Family reference |

- **Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) delivering a malicious `.proj / .zip` project file opened by an engineer in Designer, achieving code execution on the EWS and enabling [T0889 Modify Program](#) on downstream controllers.

## Group E — SQL Historian backends — Purdue L3 data tier

- **Direct attack surface** — Gateway holds plaintext-recoverable DB credentials in its internal config DB (encrypted at rest with a key co-located on disk). Compromise of the Gateway = compromise of every historian DB it talks to. TCP 1433 (MSSQL) / 5432 (Postgres) / 3306 (MySQL).
- **Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) — pivot from Gateway to historian for process-recipe theft or pre-attack reconnaissance, often a precursor to [T0832 Manipulation of View](#) via historian-derived dashboards.

## Logging matrix (highest priority)

| Source                              | Event                                                                                      | What it catches                              | MITRE ATT&CK ICS      |
|-------------------------------------|--------------------------------------------------------------------------------------------|----------------------------------------------|-----------------------|
| Gateway<br><code>wrapper.log</code> | <code>Login attempt</code> for user <code>admin</code> from non-engineer IP                | Default-cred abuse                           | <a href="#">T0812</a> |
| Gateway audit log                   | Module install / project import                                                            | Malicious <code>.mod1</code> or project drop | <a href="#">T0866</a> |
| Gateway audit log                   | Gateway Network connection added                                                           | Lateral L3-to-L3 SCADA pivot                 | <a href="#">T0866</a> |
| Linux auditd                        | <code>execve</code> of <code>java</code> with non-standard <code>-Dignition.*</code> flags | Tampered launch wrapper                      | <a href="#">T0857</a> |
| Linux auditd                        | Write to <code>/usr/local/bin/ignition/data/</code> outside maintenance window             | Project/script tamper                        | <a href="#">T0889</a> |

| Source                   | Event                                             | What it catches                                   | MITRE ATT&CK ICS      |
|--------------------------|---------------------------------------------------|---------------------------------------------------|-----------------------|
| Sysmon (Windows Gateway) | Ignition.exe spawning<br>cmd.exe / powershell.exe | Jython system.util.execute abuse                  | <a href="#">T0853</a> |
| Network (Zeek)           | Outbound TCP 8060 to non-redundancy peer          | Rogue Gateway Network peer                        | <a href="#">T0830</a> |
| OPC UA server logs       | New anonymous-policy session                      | OPC UA reconnaissance / unauthorized command path | <a href="#">T0855</a> |

**Secondary:** Gateway `system_console.log` script errors (Jython stack traces from tag-change scripts); Gateway audit log for tag writes from operator accounts (compare to baseline operator behavior, watching for [T0836 Modify Parameter](#)); MS SQL `xp_cmdshell` / Postgres `COPY PROGRAM` near Gateway connection windows; Sparkplug B `NBIRTH` / `NDEATH` storm patterns; redundant-pair failover events without an operator ticket; auditd on `/var/lib/ignition/data/db/config.idb` (the encrypted credential store).

## Specific zero-day-ish concerns for your dataset

1. **Default admin/password survives into production.** First field check on any Ignition site — try the default. Inductive Automation's installer asks but does not force rotation. Triage Gateway audit logs for `admin` logins from non-engineer subnets first ([T0812 Default Credentials](#)).
2. **Gateway Network trust is transitive.** Any compromised peer Gateway can push project resources to its partners (EAM agent pattern). Hunt for unexpected Gateway Network peers, especially over TCP 8060 to non-redundancy hosts, and confirm `.mod1` signing policy is enforced ("Strict" mode).
3. **Jython on the Gateway = SYSTEM/root code execution.** Tag-change scripts, gateway timer scripts, and message handlers run inside the JVM with full Gateway privileges. A single tampered project resource = persistence and a direct path to [T0889 Modify Program](#) on downstream PLCs. Baseline the project XML/JSON and diff weekly.
4. **Perspective Workstation embeds Chromium (JxBrowser).** Track JxBrowser CVE feed independently — it lags Chrome upstream by weeks. The L2 operator HMI is now a browser threat model, not a thick-client one; browser RCE on a Perspective Workstation panel is a direct route to [T0832 Manipulation of View](#).
5. **Historian credential pivot.** The Gateway's internal config DB holds DB creds for every historian. Treat `data/db/config.idb` as a credential-vault file — auditd watch + restrict file ACLs to the `ignition` service account.

## Water-utility deployment pattern

---

Ignition Gateway on Linux is increasingly the default control-center SCADA in modern municipal water/wastewater builds, displacing legacy Wonderware (now AVEVA System Platform / AVEVA InTouch HMI) and iFIX on aging Windows. The hardening story (SELinux + auditd + systemd unit isolation) is the explicit reason integrators pick it. A "Linux + auditd water SCADA control center" in a tabletop is almost certainly Ignition. Pair the auditd rules above with [docs/purdue-l3-site-operations-brief.md](#) detection content, the L1 RTU brief at [docs/purdue-l1-basic-controllers-brief.md](#) for the lift-station Modbus/DNP3 polling side (watch for [T0855 Unauthorized Command Message](#) and [T0836 Modify Parameter](#) on setpoints, with [T0879 Damage to Property](#) as the worst-case outcome for clearwell or chemical-dosing tampering), and the L3.5 brief at [docs/purdue-l35-it-ot-boundary-brief.md](#) for any Cirrus Link / MQTT cloud agent.

## Sources

---

- Inductive Automation security bulletins — <https://inductiveautomation.com/security/>
- CISA ICSA-23-220-01 (Ignition Gateway, Claroty Team82) — <https://www.cisa.gov/news-events/ics-advisories/icsa-23-220-01>
- CISA ICSA-22-242-09 (Ignition family) — <https://www.cisa.gov/news-events/ics-advisories/icsa-22-242-09>
- CISA ICS advisories index — <https://www.cisa.gov/news-events/cybersecurity-advisories/ics-advisories>
- Claroty Team82 research — <https://claroty.com/team82/research>
- Dragos OT threat intelligence — <https://www.dragos.com/blog/>
- Forescout Vedere Labs — <https://www.forescout.com/research-labs/>
- MITRE ATT&CK for ICS — <https://attack.mitre.org/matrices/ics/>
- Inductive Automation Ignition user manual (Gateway Network, module signing) — <https://docs.inductiveautomation.com/>
- CISA water and wastewater sector resources — <https://www.cisa.gov/water>